

Fourth-Round Beginner-Fix Legal & Compliance Notice (v3.40)

Document nature: Compliance reminder for relative-date parsing, AR aging, hard-write freeze, cross-user audit search, order comparison, delete undo. **Does not constitute legal advice.** Cumulatively applies to all §6 disclaimers in v3.25.10 → v3.39.

Chinese version: [POLISH_V340_LEGAL_NOTICE_ZH.md](#)

 **Customer MUST have CPA / legal counsel / internal control officer review before production use.**

 v3.40 includes highly sensitive functions

Function	Risk Level	Legal Sensitivity
Freeze hard-write safe mode (M5)	 System-wide impact	Corporate governance, internal control
Delete undo (90-sec recover) (M4)	 Data restoration	PDPA, Trade Secrets Act
Cross-user audit search (M6)	 Employee surveillance	Labor law, PDPA
AR aging query (M2)	 Customer financial status	Business Accounting Act, PDPA
Order compare (M7)	 Internal use	Trade secret
Relative date parsing (M1)	 Pure helper	—

1. Freeze Hard-Write Safe Mode (M5)

1.1 Behavior

- Owner / sysadmin says "freeze hard-write for 14 days"
- During freeze: all write LLM tools system-wide refuse to execute
- READ tools work normally

- The unfreeze tool itself is **not blocked** (avoid lockout)

1.2 High-Privilege Sensitivity

- This function can **paralyze** company-wide write operations
- Limited to users with **system.config.update** permission
- Customer must:
 - Restrict this permission to **owner + 1 backup**
 - **Written notice** to all employees before freezing
 - **Written notice** when unfreezing

1.3 Legal Risks

During freeze, may cause:

- ● **Customer order failures** → business loss / customer churn
- ● **Missed supplier delivery dates** → penalty liability
- ● **Employee work delays** → labor contract disputes
- ● **Tax filing delays** → fines

1.4 Customer Internal Control Duties

- Freeze must have **legitimate reason** (e.g., owner travel, audit in progress, incident response)
- During freeze, **audit log still records** all LLM conversations + rejected operations
- Unfreezing does **not automatically replay** rejected operations — employees must re-do

1.5 erpilot Disclaimer

To the maximum extent permitted by applicable law, erpilot is **not liable** for **any loss** (business loss, customer churn, penalties, tax fines, labor disputes) arising from hard-write freeze.

2. Delete Undo (90-sec recover) (M4)

2.1 Behavior

- After delete of customer / supplier / part, say "undo" within 90 sec to restore
- Restoration **rebuilds the original row** (with original ID, code, created_at)
- If the same code has been **reused** within 90 sec → restoration rejected

2.2 PDPA / Statutory Retention

The legal effect of deletion is **not** changed by undo:

- Business Accounting Act §38: transaction vouchers must be kept 5 years — **delete + undo within 90 sec** still counts as "once deleted"
- PDPA: after exercising "right to be forgotten", **post-delete restoration** may violate user intent
- GDPR-equivalent: "restore after delete" may require data subject notification

2.3 Customer Internal Control Duties

- Deletion should require **pre-approval** (not "we can undo it anyway")
- Restoration should have **audit log** (who, why)
- Should **not** maliciously delete-then-undo to **hide audit trail** (considered internal control violation)

2.4 In-Memory Limits

- Undo stack is **single-process in-memory**
- Backend restart / docker compose restart → undo stack cleared
- Multi-worker deployment does **not share** (v3.x roadmap: Redis sharing)
- Customer should **not rely** on undo as replacement for proper backup

2.5 erpilot Disclaimer

erpilot is **not liable** for **data unrecoverable** due to undo failure (backend restart / code reuse / expiration).

3. Cross-User Audit Search (M6)

3.1 Behavior

- Any logged-in user can say "who changed customer ABC last month"
- System lists **actor / action / entity / timestamp**

3.2 Employee Surveillance Boundary

Important: Cross-user audit search involves **employee behavior records**:

- Falls under labor law's "employee monitoring" scope
- Notification / consent requirements vary by jurisdiction
- Taiwan: employee **should be informed in labor contract** that the employer has the right to monitor electronic operations
- EU GDPR: requires legal basis (contract / consent / legitimate interest)

3.3 Customer Internal Control Duties

- Restrict audit search permission to **HR / legal / internal audit / IT lead**

- Employee **must sign** "electronic operations may be audited" consent
- Audit records **must not** be used for **personal attack** or **discrimination**
- Audit retention should match **personnel data retention**

3.4 erpilot Disclaimer

erpilot is **not liable** for **labor disputes**, **privacy lawsuits**, **PDPA complaints** due to misuse of audit search.

4. AR Aging Query (M2)

4.1 Behavior

- Lists customer × outstanding amount × due date × days overdue
- With "status flag" (● > 30 days / ● overdue / ● normal)

4.2 Legal Sensitivity

AR aging data is:

- **Customer's financial status** (protected under PDPA Article 6 — not "sensitive PII" but high sensitivity)
- **Business Accounting Act's "external data"** (leak = confidentiality breach)

4.3 Customer Internal Control Duties

- **Do not** send AR list to **unauthorized third parties** (peers, banks, credit bureaus without customer consent)
- Externally mentioning customer overdue **may constitute defamation** (must have written evidence)
- Collection actions must follow **debt collection guidelines** (industry-analogously applicable even for non-financial institutions)

4.4 erpilot Disclaimer

erpilot is **not liable** for **defamation**, **PDPA**, **customer complaints** due to AR aging data leak, misuse, improper collection.

5. Order Compare (M7)

5.1 Behavior

- Compare two SO/PO: total, item count, status, customer/supplier, order date

5.2 Risk

- Comparison may reveal **differential pricing** between Customer A vs B → potential discriminatory pricing concern under **Fair Trade Act**
- Leakage may violate **Trade Secrets Act**

5.3 Customer Responsibility

- Compare results are **internal use only**
- Do not **screenshot / print** and leak

6. Relative Date Parsing (M1)

6.1 Behavior

- "Last week" / "past 30 days" / "Q1" → actual date range

6.2 Limits

- Parsing is based on **server timezone** (UTC)
- If customer is in Taiwan timezone, "today" near UTC midnight may differ by 1 day — **watch cross-day boundary**
- Religion / national holiday relative descriptions ("Mid-Autumn Festival", "before Chinese New Year") not supported — v3.x roadmap

6.3 erpilot Disclaimer

erpilot is **not liable** for **report errors**, **miscalculated delivery dates** due to date parsing errors; customer should **manually verify** important date calculations.

7. Case Studies: Common Misuse

7.1 ❌ Don't

- Freeze hard-write **without notice** to employees → they think system is broken
- Use Delete-Undo to **hide mistakes** (change wrong customer → delete → undo, pretend nothing happened)
- Use audit search to **target specific employees** for discrimination
- Screenshot AR aging and **send to LINE group** to discuss customers
- Send order comparison **to the counterparty** for negotiation

7.2 Do

- Announce company-wide **before freezing** with **clear unfreeze date**
- Use Delete-Undo for **genuine mistakes**, with **note in audit log**
- Use audit search for **internal control, audit, incident response**
- **Encrypt and mail AR list to CPA**
- Use order comparison for **internal negotiation strategy only**

8. Disclaimer (Cumulative v3.25.10 → v3.40)

To the maximum extent permitted by applicable law:

1. **Freeze hard-write** Freeze is an execution tool for **customer's internal decision**; erpilot is **not liable** for **any loss** (business loss, breach, tax fines, labor disputes) caused by freezing.
2. **Delete Undo** Undo is a **convenience feature**; erpilot is **not liable** for **statutory retention, PDPA rights, contractual obligation** disputes from undo failure, misuse, or malicious use.
3. **Cross-user Audit Search** is an **internal control tool**; erpilot is **not liable** for **labor disputes, PDPA complaints, employee discrimination** claims from misuse.
4. **AR Aging Query** is a **convenience feature**; erpilot is **not liable** for **defamation, PDPA, customer complaints** from data leak, misuse, improper collection.
5. **Order Compare Comparison** is an **internal analysis tool**; erpilot is **not liable** for **Fair Trade Act, Trade Secrets** disputes from leaked results.
6. **Relative Date Parsing** is a **heuristic helper**; erpilot is **not liable** for **business decision errors** from date calculation errors.

9. Pre-Adoption Checklist (v3.40 reinforced)

9.1 High-Privilege Control

- ☐ `system.config.update` (freeze permission) **only granted to owner + 1 backup**
- ☐ `system.audit.read` (if separated) granted only to HR / legal / internal audit / IT lead
- ☐ Established "freeze announcement → unfreeze announcement" **written process**

9.2 Employee Notice

- ☐ Labor contract / employee handbook **explicitly states**: electronic operations may be audited
- ☐ Employees **sign consent** (electronic signature OK)
- ☐ At least one annual "security + PDPA" training

9.3 Internal Control Policy

- ☐ Established "Delete-Undo must log reason" internal control rule
- ☐ Established "AR list external transmission" approval flow
- ☐ Established "order compare results internal-use only" confidentiality policy

9.4 Technical Configuration

- ☐ Backend timezone set to **Taiwan (Asia/Taipei)** or company location (affects M1 parsing)
- ☐ Backup scheduled (during M5 freeze, still need backup)

9.5 Cumulative with Existing Checklists

- ☐ Completed all v3.25.10 → v3.39 checklists

10. International / Cross-Border Warning

If customer's business spans multiple markets:

Region	Additional Law	Impact on v3.40
eu EU	GDPR	Delete Undo requires data subject notification; audit search needs legal basis
us US (CA)	CCPA	Customer has "right to delete" — undo may violate
cn China	PIPL	Audit search must comply with "explicit purpose, necessity, minimum scope"
jp Japan	APPI	Cross-border transfer (e.g., customer data) requires extra consent
sg SG	PDPA	DNC list restricts collection calls

erpilot does not automatically handle cross-border compliance; customer must **self-consult** local legal counsel.

Version: v3.40 (2026-05-21) **Author:** erpilot Legal Team (internal) **Corresponds to code:**

- `backend/app/agents/domains/polish_v340_tools.py` (5 LLM tools + helper)
- `backend/app/agents/domains/polish_tools.py` (push_undo + delete restoration)

- `backend/app/agents/domains/polish_v339_tools.py` (delete trio added push_undo)
- `backend/app/agents/engine.py` (freeze blocker)
- `backend/app/agents/domains/hard_write_tools.py` (case-insensitive search)